

Security+ 2.2 · Other Social Engineering

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.2 — Other Social Engineering (3:29)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Social engineering beyond email includes: misinformation (spreading false information at scale), brand impersonation (posing as support), pretexting (inventing a plausible scenario to justify a request, e.g., 'I'm an auditor, I need to verify X'), dumpster diving (sensitive paper in trash), and shoulder surfing.

High-Yield Core Concepts Tested on Exam

- Pretexting: a FALSE but plausible scenario that justifies the request
- Misinformation: spreading false information at scale (e.g., social media) to further an objective
- Brand impersonation: attacker poses as a trusted brand or support entity
- Dumpster diving and shoulder surfing are physical social engineering tactics

Exam Tips & Classic Scenarios

- 'creates a fabricated scenario to obtain information' = pretexting
- 'spreading false information to influence' = misinformation
- 'pretending to be technical support' = brand impersonation

Typical Exam Scenario: Scenario: 'someone calls pretending to be an auditor and asks for credentials to verify X' = pretexting.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.2 — Other Social Engineering)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A scammer calls pretending to be IT support and creates urgency for you to give your password. The social engineering principle exploited is:

- A)** Scarcity
- B)** Authority + urgency
- C)** Social proof
- D)** Reciprocity

2. An employee receives a call from someone pretending to be technical support asking for a password for a 'system update'. What technique is this?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

3. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Pretexting: FALSE but plausible scenario that justifies the request'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: Pretexting: FALSE but plausible scenario that justifies the request...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

4. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Misinformation: disinformation at scale (social media) to further an objective.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: Misinformation: disinformation at scale (social media) to further an objective...**

5. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'creates a fabricated scenario to obtain information' = pretexting'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'creates a fabricated scenario to obtain information' = pretexting.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.2) exam, an analyst evaluates the following technical requirement: 'Scenario: 'someone calls pretending to be an auditor and asks for credentials to verify X' = pretexting.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'someone calls pretending to be an auditor and asks for credentials to veri...
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Pretexting: FALSE but plausible scenario that justifies the request'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Pretexting: FALSE but plausible scenario that justifies the request...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Misinformation: disinform at scale (social media) to favor an objective'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Misinformation: disinform at scale (social media) to favor an objective...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'creates a fabricated scenario to obtain information' = pretexting'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'creates a fabricated scenario to obtain information' = pretexting...

10. Corporate scenario (Other Social Engineering): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Scenario: someone calls pretending to be an auditor and asks for credentials to verify X = pretexting.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: someone calls pretending to be an auditor and asks for credentials to verify X = pretexting...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Authority + urgency.

✓ **Why it's correct:** The correct alternative is 'Authority + urgency'. Social engineering exploits cognitive biases and psychological principles to manipulate victims. In the scenario, the scammer impersonates IT support, which invokes the principle of authority (the victim tends to obey authority figures). Additionally, he creates a sense of urgency to pressure the victim to act quickly, without thinking critically. The combination of authority and urgency is a classic social engineering tactic, recognized by CompTIA. Therefore, the option 'Authority + urgency' accurately describes the principles exploited.

✗ **Why the others are wrong:**

- *Scarcity*: Scarcity is a persuasion principle that exploits the perception that resources are limited, creating a feeling that the opportunity may be lost if not acted upon immediately. In the scenario, there is no mention of scarce resources or limited offers. The scammer is not offering something in limited quantity, but rather impersonating authority and creating urgency. Therefore, scarcity is not the applicable principle.
- *Social proof*: Social proof is the tendency for people to follow the behavior of others, assuming that actions taken by many are correct. In the described attack, there is no mention of other people doing the same or endorsing the action. The scammer does not use the idea that 'everyone is doing it' to convince the victim. Therefore, social proof is not the principle exploited.
- *Reciprocity*: Reciprocity is the principle that people feel obliged to return a favor or concession. In the scenario, the scammer does not offer anything first and then ask for the password; he simply impersonates support and creates urgency. There is no exchange of favors. Therefore, reciprocity does not apply.

2) A — Vishing.

✓ **Why it's correct:** The correct answer is 'Vishing'. Vishing is a combination of 'voice' and 'phishing', i.e., social engineering conducted via telephone calls (VoIP or traditional telephone network). In the described scenario, the attacker impersonates technical support to obtain the victim's password, exactly characterizing a vishing attack. CompTIA Security+ classifies vishing as a voice-based social engineering attack, where real-time interaction increases psychological pressure and perceived credibility. The goal is to induce the victim to reveal credentials or perform harmful actions.

✗ **Why the others are wrong:**

- *Pretexting*: Pretexting is the creation of a false scenario or pretext to obtain information. Although the attacker in the statement uses a pretext (fake technical support), the primary vector is the telephone. Pretexting is a common element in many social engineering attacks, including vishing, phishing, and smishing. The alternative is incorrect because it does not specify the telephone channel, which is the defining characteristic of vishing. Technically, pretexting is the technique of building the story, while vishing is the delivery method via voice.
- *Baiting*: Baiting involves leaving a physical device (such as an infected USB drive) or a digital lure for the victim to use, exploiting curiosity. There is no relation to telephone calls or direct password requests by voice. The alternative is incorrect because it describes an attack that depends on physical action or interaction with removable media, not real-time verbal interaction.
- *Tailgating*: Tailgating is a physical unauthorized access technique where the attacker follows an authorized employee through a secure door without authenticating. It does not involve telephone, verbal social engineering, or obtaining a password. The alternative is incorrect because it belongs

to the category of physical attacks, while the scenario describes a remote voice social engineering attack.

3) B — Implement the corresponding solution: Pretexting: FALSE but plausible scenario that justifies the request....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): Pretexting: FALSE but plausible scenario that justifies the request. Pretexting is a social engineering tactic where an attacker creates a fabricated scenario to manipulate a victim into divulging information or performing actions.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) D — Implement the corresponding solution: Misinformation: disinformation at scale (social media) to further an objective....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): Misinformation: disinformation at scale (social media) to further an objective.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) B — Implement the corresponding solution: 'creates a fabricated scenario to obtain information' = pretexting..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): 'creates a fabricated scenario to obtain information' = pretexting. Pretexting involves creating a false scenario to manipulate a target into divulging information or performing actions. Defenses include security awareness training and verification procedures.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Scenario: 'someone calls pretending to be an auditor and asks for credentials to verify....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): Scenario: 'someone calls pretending to be an auditor and asks for credentials to verify X' = pretexting. Pretexting is a social engineering technique where the attacker creates a fabricated scenario (pretext) to manipulate the victim into divulging sensitive information or performing actions.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Pretexting: FALSE but plausible scenario that justifies the request....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): Pretexting: FALSE but plausible scenario that justifies the request. Pretexting is a social engineering technique where the attacker creates a fabricated scenario (pretext) to engage the victim and extract information or persuade them to perform an action. The pretext often involves impersonating a trusted individual (e.g., IT support, auditor, or executive) and providing a plausible reason for the request. Defenses include security awareness training, verification procedures, and zero-trust principles.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Misinformation: disinform at scale (social media) to favor an objective....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): Misinformation: disinform at scale (social media) to favor an objective. Misinformation is a social engineering tactic that spreads false or misleading information

to manipulate public perception, create confusion, or achieve a specific goal, often via social media platforms.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'creates a fabricated scenario to obtain information' = pretexting....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): 'creates a fabricated scenario to obtain information' = pretexting.

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Scenario: someone calls pretending to be an auditor and asks for credentials to verify X = pretexting....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Other Social Engineering): Scenario: someone calls pretending to be an auditor and asks for credentials to verify X = pretexting. Pretexting is a social engineering technique where the attacker creates a fabricated scenario (pretext) to manipulate the victim into divulging information or performing actions. In this case, impersonating an auditor to request credentials is a classic pretexting attack. The correct control is to implement awareness training and verification procedures to recognize and resist such manipulation.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.